Internal Audit Program

Date	Version	Author	Description	Approved By	Last Updated	Review Frequency	Next Review

Purpose

The purpose of this Internal Audit Program is to establish a structured approach for evaluating the effectiveness and compliance of the Information Security Management System (ISMS) at Stark Industries Inc., ensuring continual improvement and alignment with ISO/IEC 27001:2022 requirements.

Scope

Covers all processes, systems, and controls within the ISMS scope, including but not limited to:

- Cloud platforms (AWS)
- SaaS platform development and operations
- Supporting internal tools and infrastructure
- Policies, procedures, and training
- Third-party/vendor management

Objective

- Verify conformity with ISO 27001 requirements and internal policies
- Identify nonconformities, risks, and opportunities for improvement
- Ensure ISMS objectives are being met
- Validate the effectiveness of implemented controls from the Statement of Applicability (SoA)

Audit Criteria

- ISO/IEC 27001:2022 standard requirements
- Stark Industries Inc.’s ISMS policies and procedures

- Legal, regulatory, and contractual obligations relevant to the SaaS platform

Audit Frequency and Schedule

- The entire ISMS scope will be audited **annually**.
- Additional audits may be scheduled:
  - After major changes to the ISMS or operations
  - In response to significant incidents or nonconformities
  - As directed by management review decisions

Audit Period	Focus Areas	Lead Auditor	Planned Date
Annual Audit	Full ISMS scope	Appointed Internal Auditor	[Insert Date]
Additional Audits	Targeted areas (e.g. incidents, high-risk controls)	Appointed Internal Auditor	As required

Auditors and Independence

- Auditors must be **independent of the area being audited**.
- The Information Security Manager assigns auditors based on competence and impartiality.
- External resources may be used for complex areas or to support independence.

Methods of Audit

- Document reviews (policies, logs, reports)
- Interviews with relevant personnel
- Observation of processes and control implementation
- Sampling of records and evidence
- Testing of operational controls where applicable

Audit Records

- Audit plan and schedule
- Audit checklists and working papers
- Evidence collected during the audit
- Audit reports and findings
- Corrective Action Requests (CARs) and follow-up records

Reporting and Follow-up

- Audit reports will be issued to management within 14 days of audit completion.
- Corrective actions will be tracked and closed based on severity and deadlines.
- Results are reviewed in the **Management Review (Clause 9.3)**.

Review and Updates

- This Audit Program is reviewed annually and after major ISMS changes.
- Lessons learned and feedback from audits are used to improve the audit process.